TP : REALISER UNE ANALYSE DE VULNÉRABILITÉS COMPLÉTE SUR UNE MACHINE VIRTUELLE METASPLOITABLE2 ET PRODUIRE UN RAPPORT

Realiser par HAYE FALL

29 DÉCEMBRE 2025

Sommaire

Screenshot de installation **1**

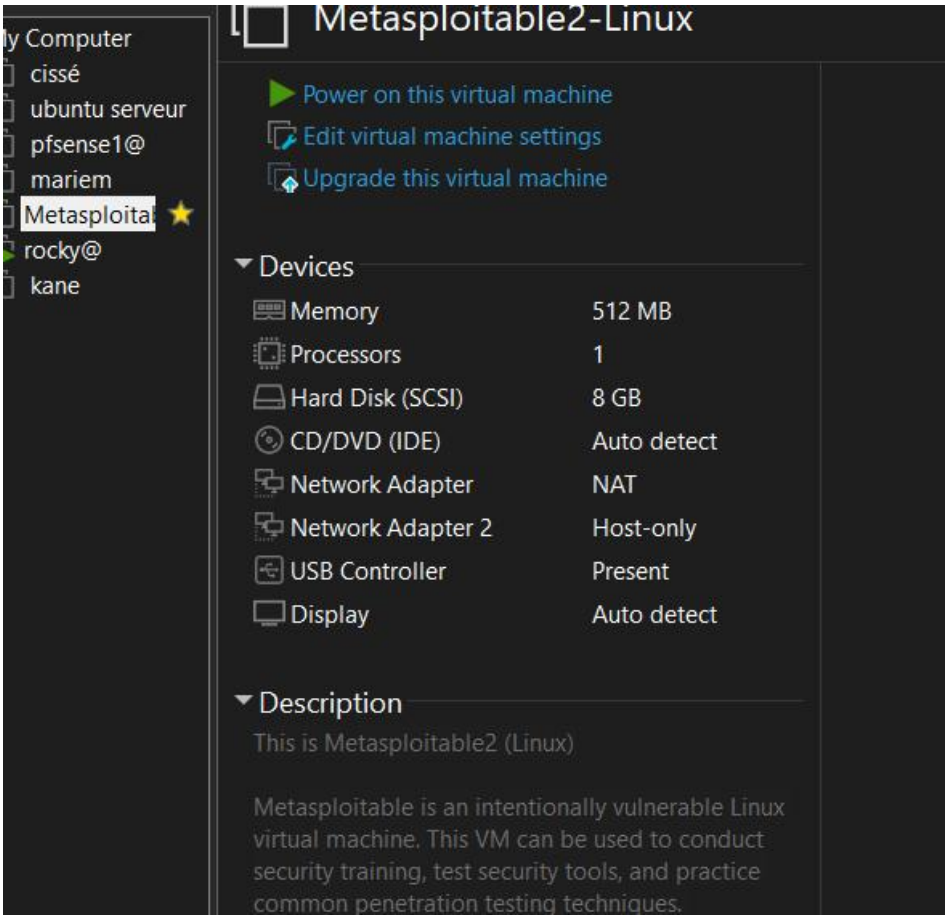
Capture du scan OpenVAS.....2

Capture du scan Nessus..... 3

Tableau comparatif **4**

Plan d’action correctif 5

Metasploitable 2

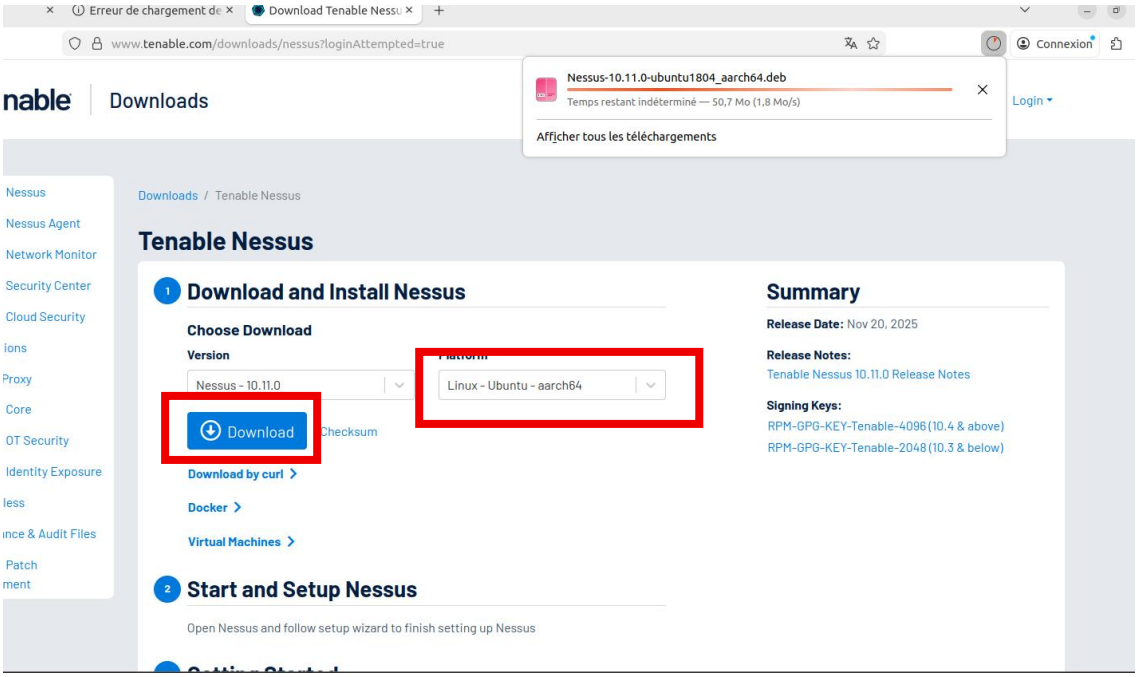



```
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ip q
Object "q" is unknown, try "ip help".
msfadmin@metasploitable:~$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 00:0c:29:c1:58:f3 brd ff:ff:ff:ff:ff:ff
    inet 192.168.88.146/24 brd 192.168.88.255 scope global eth0
    inet6 fe80::20c:29ff:fec1:58f3/64 scope link
       valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST> mtu 1500 qdisc noop qlen 1000
    link/ether 00:0c:29:c1:58:fd brd ff:ff:ff:ff:ff:ff
msfadmin@metasploitable:~$ _
```

Screenshot de installation

Installation de Nessus sur Ubuntu 22.04

Aller sur le navigateur web de la machine virtuelle ou on veus installer Nessus et taper le lien ci-dessous

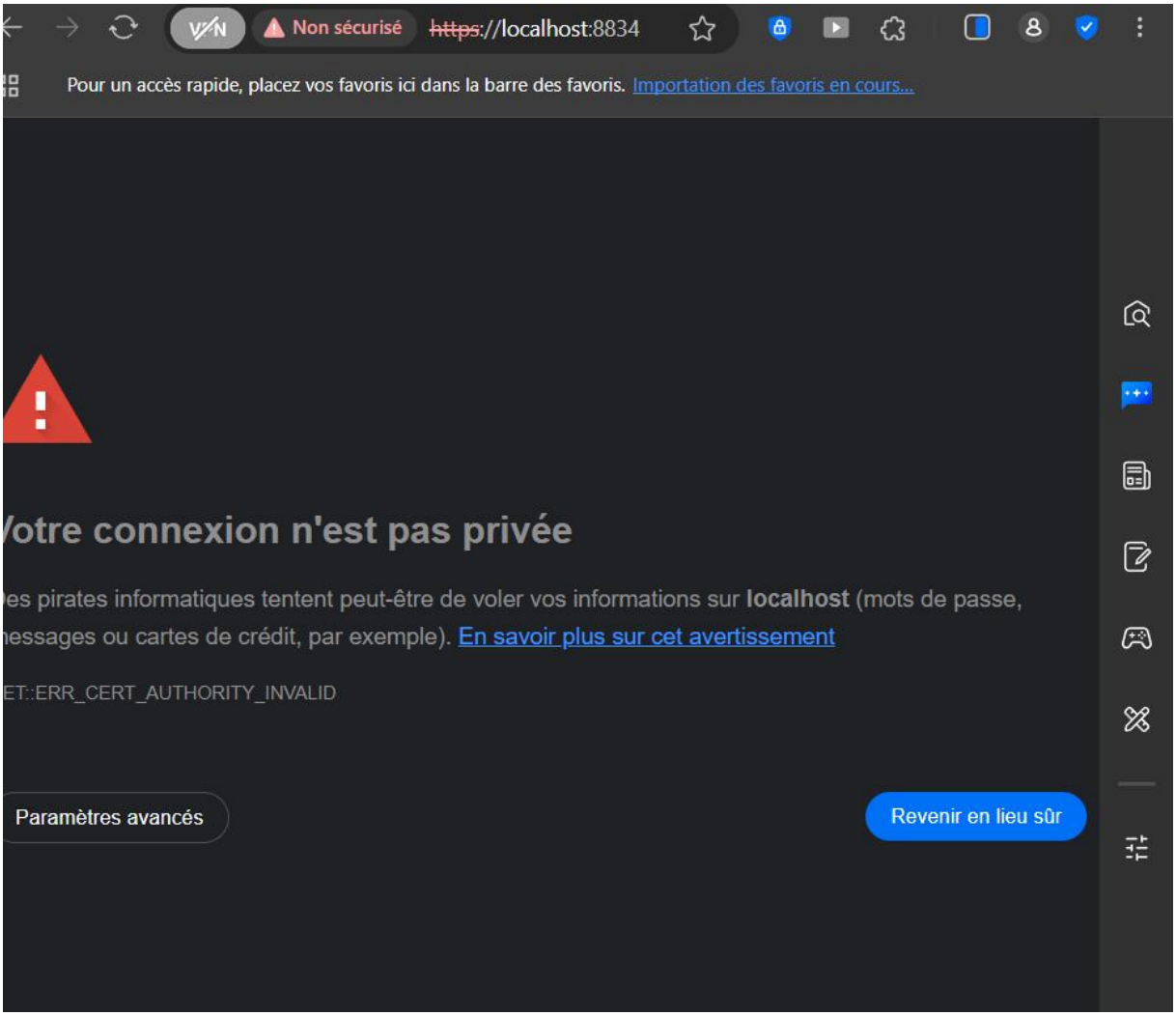


Puis aller sur le terminer et naviger avec cd pour rentrer dans téléchargement ou download puis taper la comme sudo pdkg -i

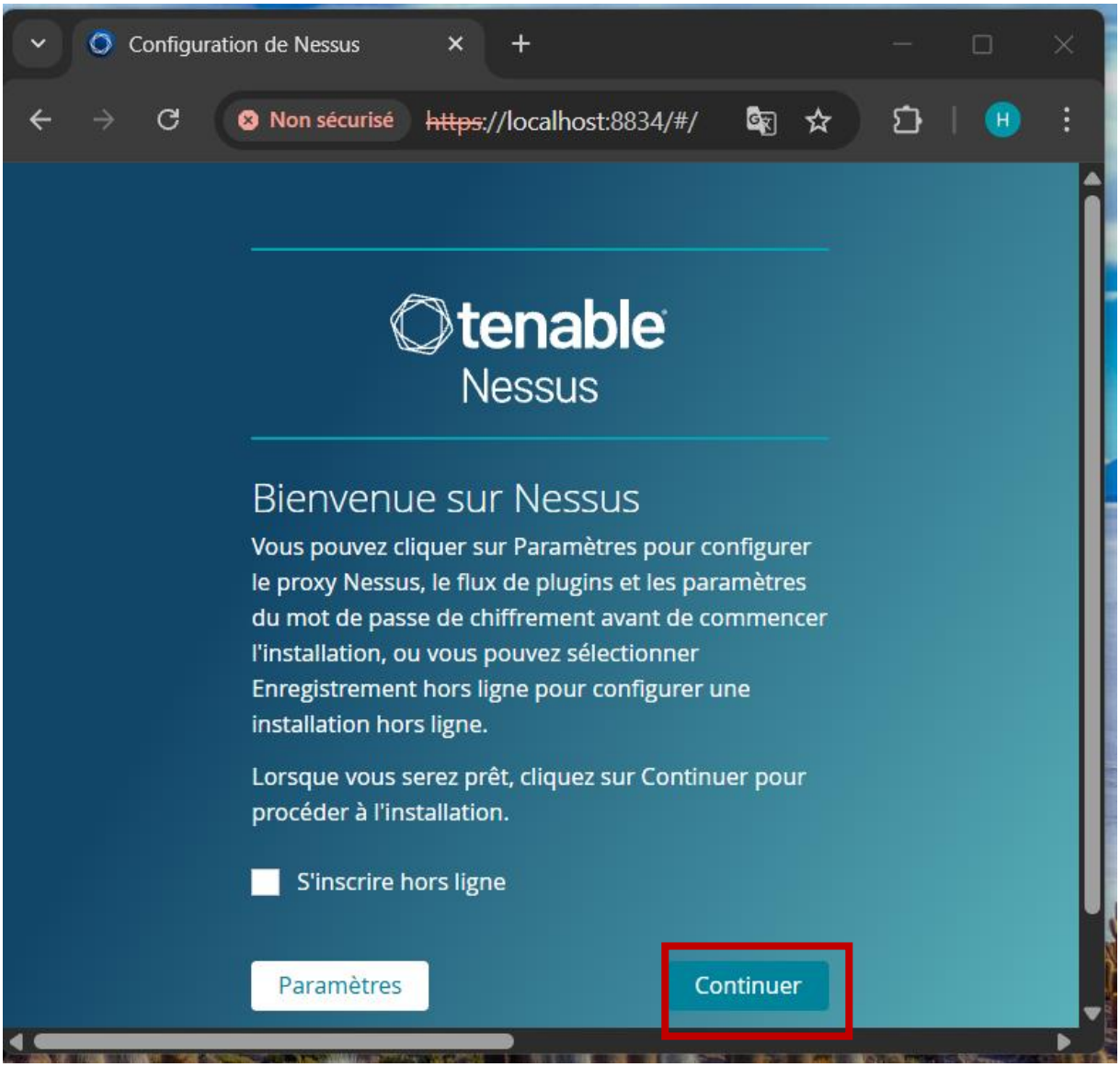
suivi du non et la version télécharger pour installer

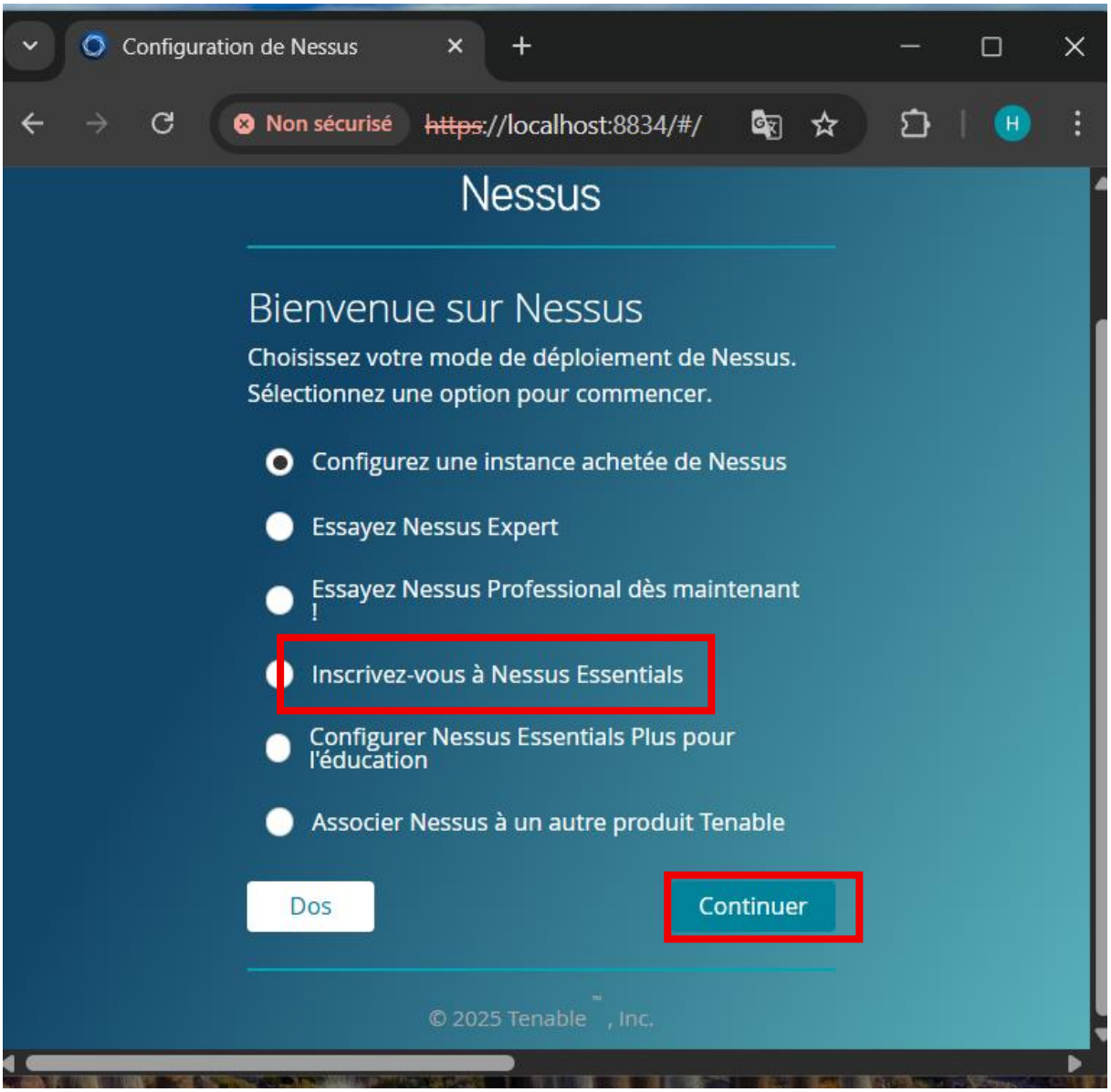
```
mariem@mariem-virtual-machine:~/Téléchargements$ ls -l
total 132336
-rw-rw-r-- 1 mariem mariem 69268228 des  8 17:12 Nessus-10.11.0-ubuntu1604_amd64
.deb
-rw-rw-r-- 1 mariem mariem 66236460 des  8 17:07 Nessus-10.11.0-ubuntu1804_aarch
64.deb
mariem@mariem-virtual-machine:~/Téléchargements$ sudo dpkg -i Nessus-10.11.0-ubu
ntu1604_amd64.deb
Sélection du paquet nessus précédemment désélectionné.
(Lecture de la base de données... 265396 fichiers et répertoires déjà installés.
)
Préparation du dépaquetage de Nessus-10.11.0-ubuntu1604_amd64.deb ...
Dépaquetage de nessus (10.11.0) ...
Paramétrage de nessus (10.11.0) ...
HMAC : (Module_Integrity) : Pass
SHA1 : (KAT_Digest) : Pass
SHA2 : (KAT_Digest) : Pass
SHA3 : (KAT_Digest) : Pass
```

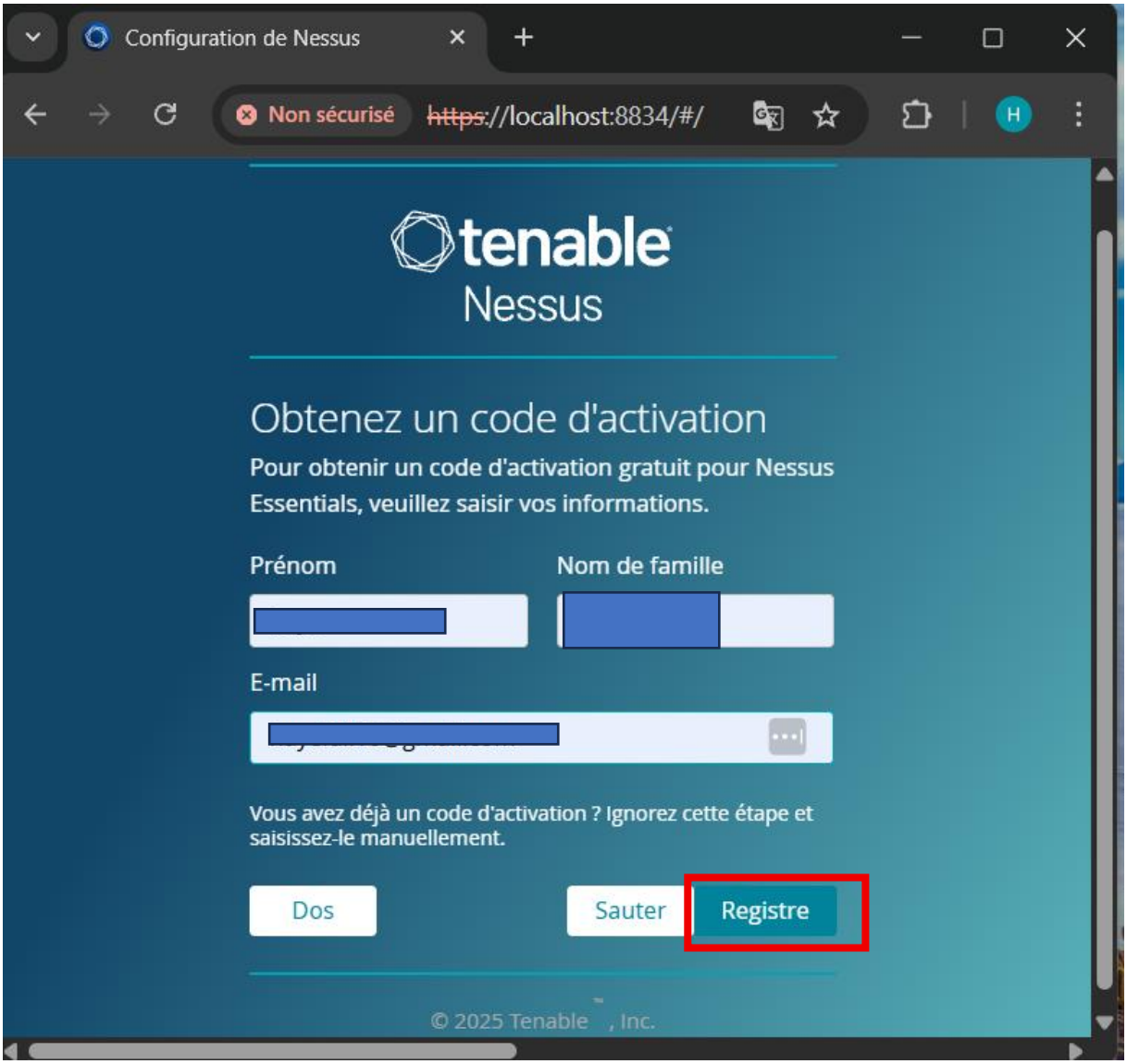
Après l’installation connecter vous a interface de nessus avec http://localhost:8834 sur le navigateur de la machine virtuelle ou elle est installer

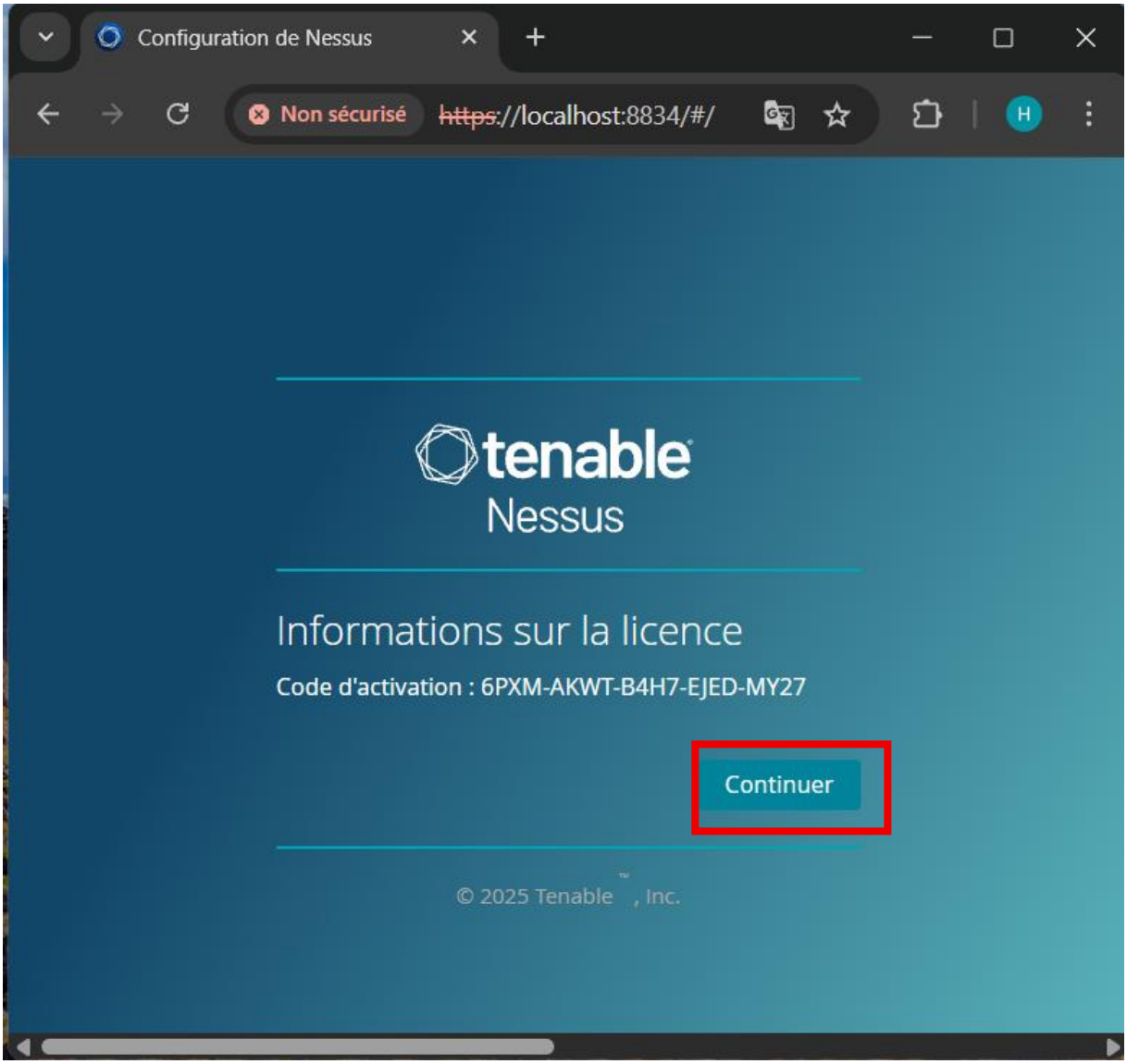


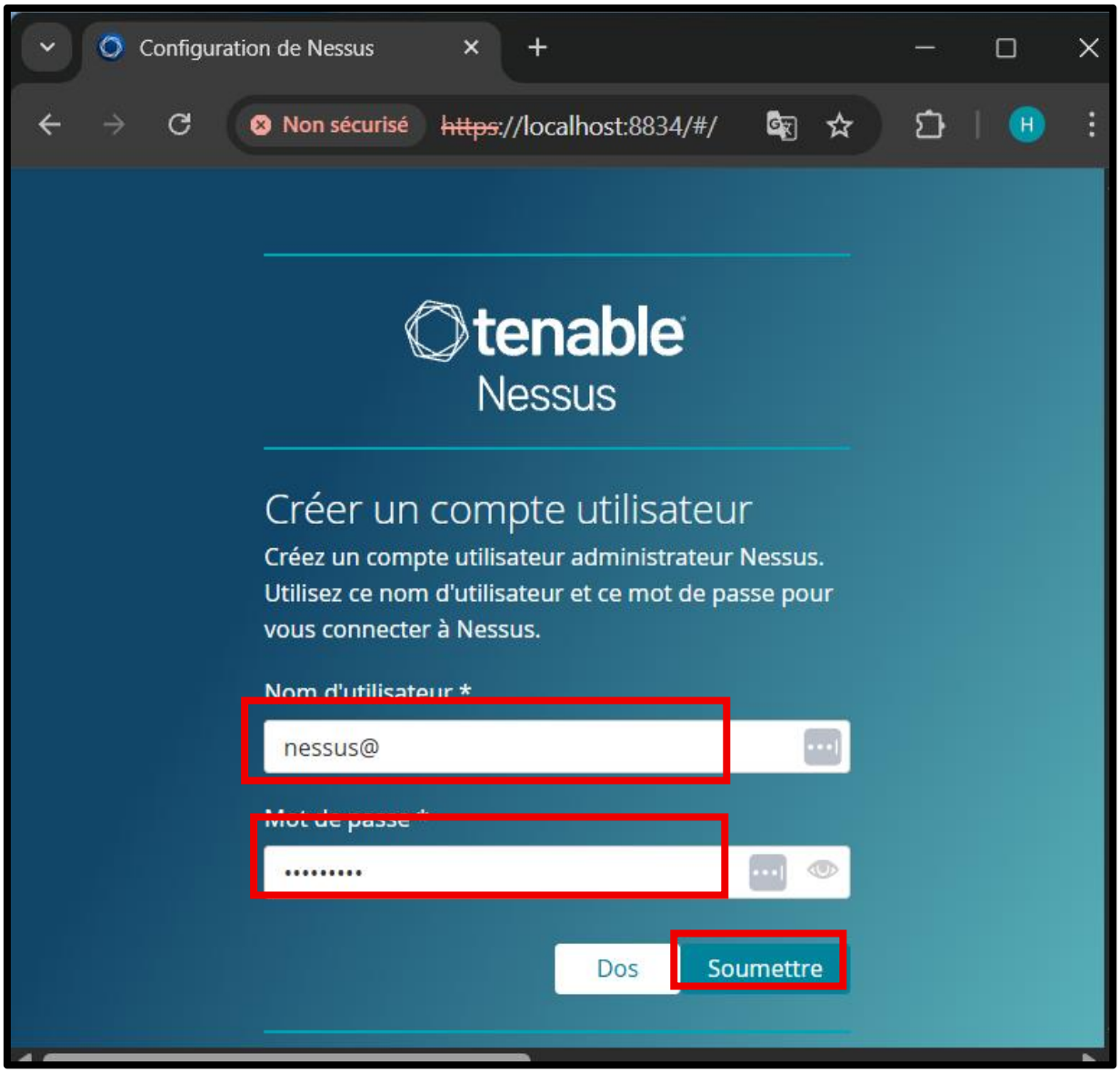
Ignorer ce message et continuer

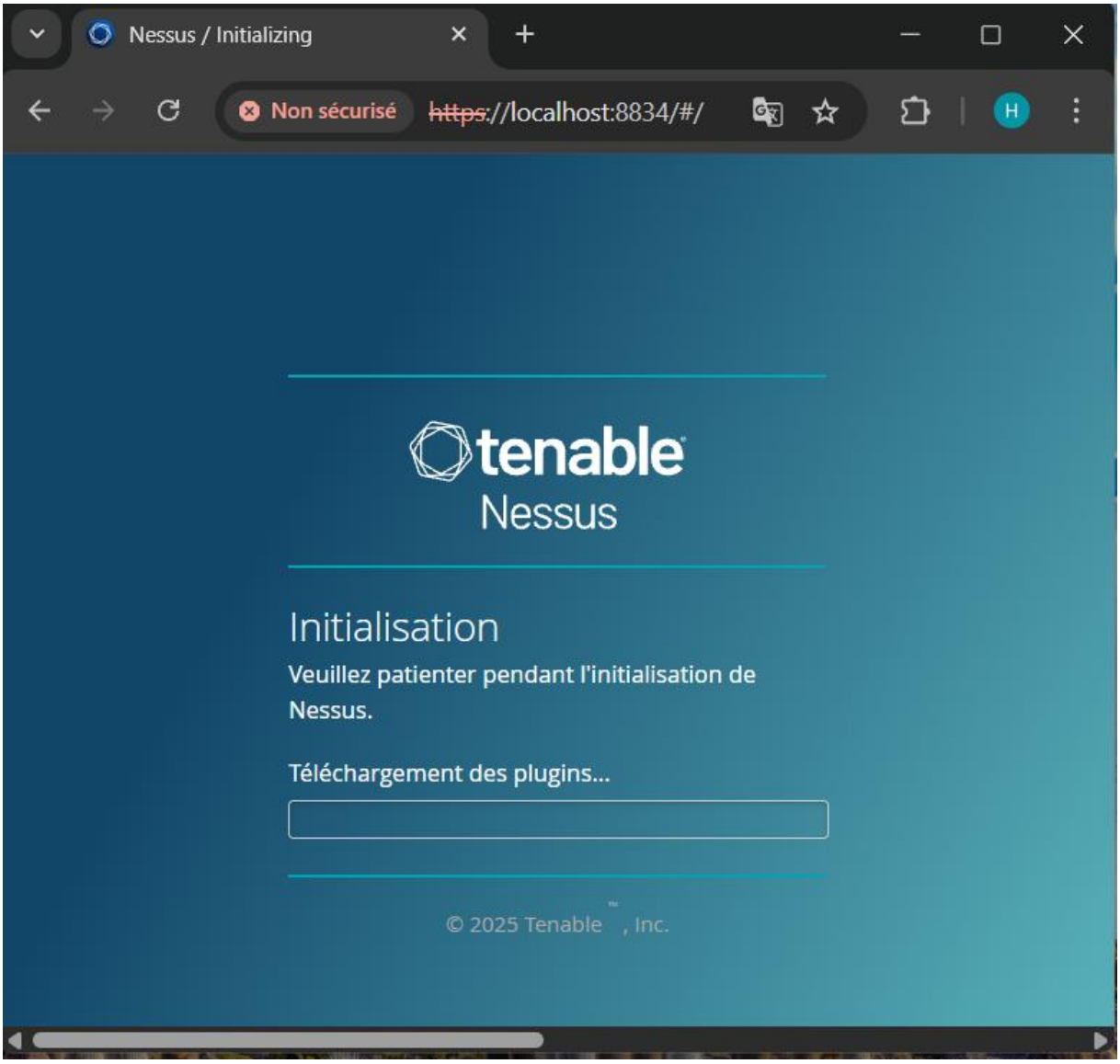

Configuration de Nessus
Non sécurisé
https://localhost:8834/#/
tenable
Nessus
Bienvenue sur Nessus
Vous pouvez cliquer sur Paramètres pour configurer le proxy Nessus, le flux de plugins et les paramètres du mot de passe de chiffrement avant de commencer l'installation, ou vous pouvez sélectionner Enregistrement hors ligne pour configurer une installation hors ligne.
Lorsque vous serez prêt, cliquez sur Continuer pour procéder à l'installation.
S'inscrire hors ligne
Paramètres
Continuer

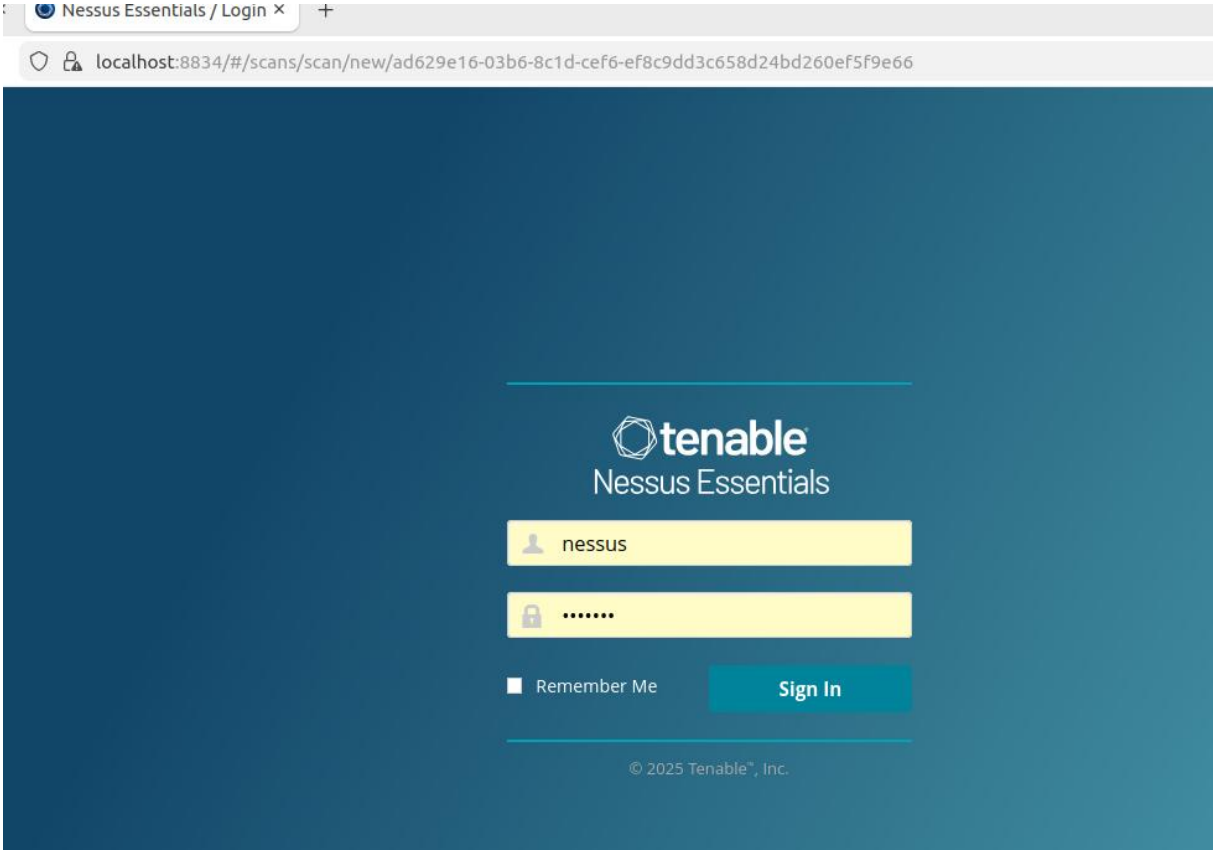

Configuration de Nessus
Non sécurisé
https://localhost:8834/#/
Nessus
Bienvenue sur Nessus
Choisissez votre mode de déploiement de Nessus.
Sélectionnez une option pour commencer.
Configurez une instance achetée de Nessus
Essayez Nessus Expert
Essayez Nessus Professional dès maintenant !
Inscrivez-vous à Nessus Essentials
Configurer Nessus Essentials Plus pour l'éducation
Associer Nessus à un autre produit Tenable
Dos
Continuer
© 2025 Tenable, Inc.


Configuration de Nessus
Non sécurisé
https://localhost:8834/#/
tenable
Nessus
Obtenez un code d'activation
Pour obtenir un code d'activation gratuit pour Nessus Essentials, veuillez saisir vos informations.
Prénom
Nom de famille
E-mail
Vous avez déjà un code d'activation ? Ignorez cette étape et saisissez-le manuellement.
Dos
Sauter
Registre
© 2025 Tenable, Inc.


Configuration de Nessus
Non sécurisé
https://localhost:8834/#/
tenable
Nessus
Informations sur la licence
Code d'activation : 6PXM-AKWT-B4H7-EJED-MY27
Continuer
© 2025 Tenable™, Inc.


Configuration de Nessus
Non sécurisé
https://localhost:8834/#/
tenable
Nessus
Créer un compte utilisateur
Créez un compte utilisateur administrateur Nessus. Utilisez ce nom d'utilisateur et ce mot de passe pour vous connecter à Nessus.
Nom d'utilisateur *
nessus@
Mot de passe *
Dos
Soumettre


Nessus / Initializing
Non sécurisé
https://localhost:8834/#/
tenable
Nessus
Initialisation
Veuillez patienter pendant l'initialisation de Nessus.
Téléchargement des plugins...
© 2025 Tenable™, Inc.



INSTALLATION DE OPENVAS SUR KALI

Utiliser la commande sudo apt upgrade pour mettre a jour le système

```
┌──(haye㉿192)-[~]
└─$ sudo apt upgrade
Les paquets suivants ont été installés automatiquement et ne sont plus nécessaires :
  curlftpfs      libconfig-inifiles-perl  libpostproc58      pocketsphinx-en-us
  libavfilter10  libfuse2t64              libsphinxbase3t64
  libavformat61  libpocketsphinx3         libswscale8
Veuillez utiliser « sudo apt autoremove » pour les supprimer.

Mis à jour :
  alsa-ucm-conf                      libqt5xml5t64
  amd64-microcode                    libqt6multimedia6
```

Installer les paquettes sudo apt install gvm

```
...

┌──(haye㉿192)-[~]
└─$ sudo apt install gvm
[sudo] Mot de passe de haye :
Désolé, essayez de nouveau.
[sudo] Mot de passe de haye :
Les paquets suivants ont été installés automatiquement et ne sont plus nécessaires :
  curlftpfs      libconfig-inifiles-perl  libpostproc58      pocketsphinx-en-us
  libavfilter10  libfuse2t64              libsphinxbase3t64
  libavformat61  libpocketsphinx3         libswscale8
Veuillez utiliser « sudo apt autoremove » pour les supprimer.

Installation de :
  gvm

Installation de dépendances :
  greenbone-security-assistant  gvm-tools           python3-terminaltables3
  gsad                          libmicrohttpd12t64

Paquets suggérés :
  python3-terminaltables3-doc

Sommaire :
  Mise à niveau de : 0. Installation de : 6, Supprimé : 0. Non mis à jour : 6
Taille du téléchargement : 2 841 ko
```

La commande **sudo gvm-setup** permet **d'installer et de configurer automatiquement Greenbone Vulnerability Management (GVM / OpenVAS)**

```
┌──(haye㉿192)-[~]
└─$ sudo  gvm-setup
This script is provided and maintained by Debian and Kali.
 If you find any issue in this script, please report it directly to Debian or Kali

[>] Starting PostgreSQL service

[>] Creating GVM's certificate files

[>] Creating PostgreSQL database
ATTENTION:  database "postgres" has a collation version mismatch
DÉTAIL : The database was created using collation version 2.41, but the operating syst
em provides version 2.42.
ASTUCE : Rebuild all objects in this database that use the default collation and run A
LTER DATABASE postgres REFRESH COLLATION VERSION, or build PostgreSQL with the right l
ibrary version.

[*] Creating database user
ATTENTION:  database "postgres" has a collation version mismatch
DÉTAIL : The database was created using collation version 2.41, but the operating syst
em provides version 2.42.
ASTUCE : Rebuild all objects in this database that use the default collation and run A
LTER DATABASE postgres REFRESH COLLATION VERSION, or build PostgreSQL with the right l
ibrary version.
ATTENTION:  database "postgres" has a collation version mismatch
```

Vérifier état de installation avec sudo gvm-check-setup

```
┌──(haye㉿192)-[~]
└─$ sudo gvm-check-setup
[sudo] Mot de passe de haye :
gvm-check-setup 25.04.0
 This script is provided and maintained by Debian and Kali.
  Test completeness and readiness of GVM-25.04.0
Step 1: Checking OpenVAS (Scanner)...
        OK: OpenVAS Scanner is present in version 23.35.3.
        OK: Notus Scanner is present in version 22.7.2.
        OK: Server CA Certificate is present as /var/lib/gvm/CA/servercert.pem.
Checking permissions of /var/lib/openvas/gnupg/*
        OK: _gvm owns all files in /var/lib/openvas/gnupg
        OK: redis-server is present.
        OK: scanner (db_address setting) is configured properly using the redis-server
 socket: /var/run/redis-openvas/redis-server.sock
        OK: the mqtt_server_uri is defined in /etc/openvas/openvas.conf
        OK: _gvm owns all files in /var/lib/openvas/plugins
        OK: NVT collection in /var/lib/openvas/plugins contains 95032 NVTs.
        OK: The notus directory /var/lib/notus/products contains 511 NVTs.
Checking that the obsolete redis database has been removed
Could not connect to Redis at /var/run/redis-openvas/redis-server.sock: No such file o
r directory
```

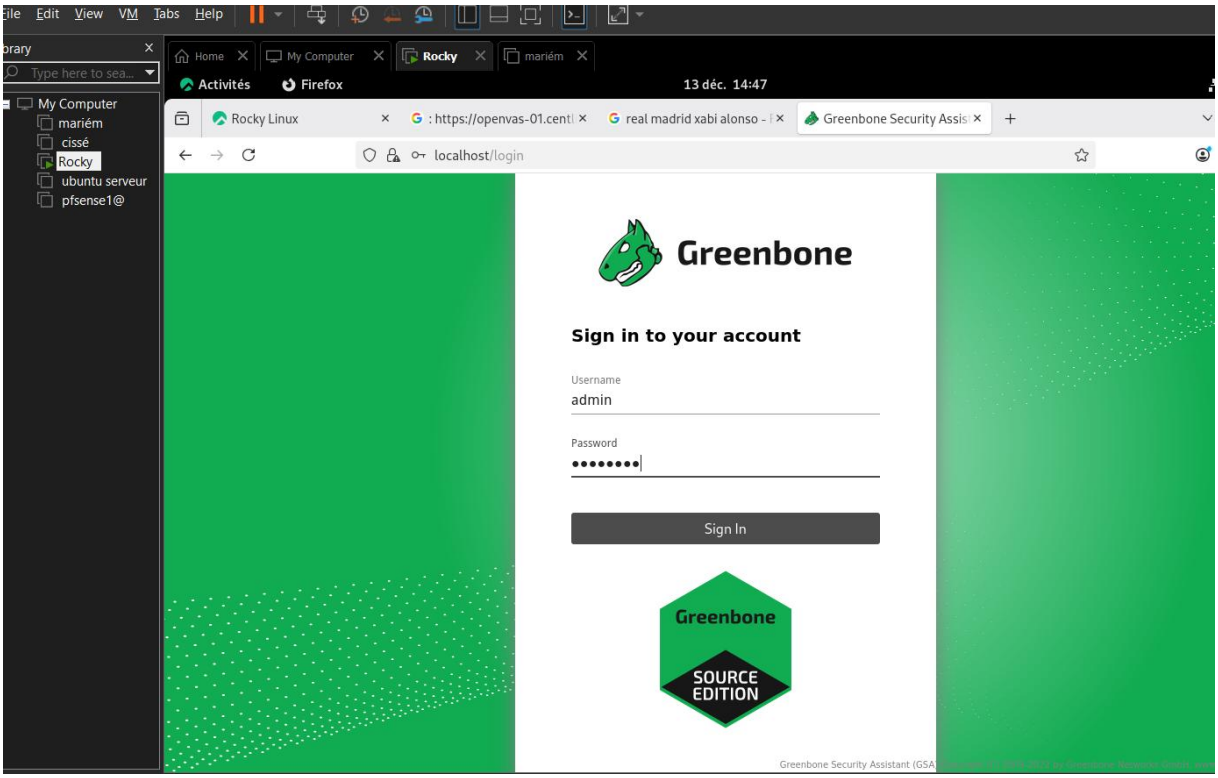
Après vérification il ya des erreur

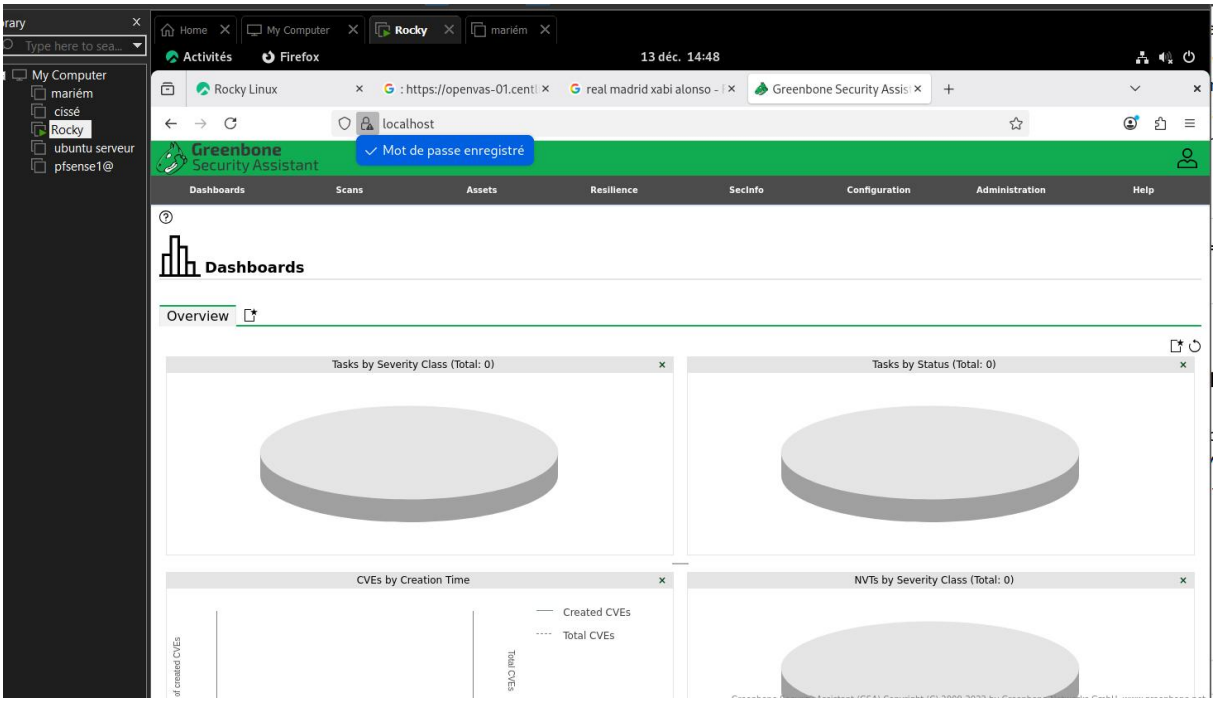
```
Step 2: Checking GVMD Manager ...
        OK: GVM Manager (gvmd) is present in version 26.12.1.
Step 3: Checking Certificates ...
        OK: GVM client certificate is valid and present as /var/lib/gvm/CA/clientcert.
pem.
        OK: Your GVM certificate infrastructure passed validation.
Step 4: Checking data ...
        ERROR: SCAP DATA are missing.
        FIX: Run the SCAP synchronization script greenbone-feed-sync.
        sudo greenbone-feed-sync --type scap.

ERROR: Your GVM-25.04.0 installation is not yet complete!

Please follow the instructions marked with FIX above and run this
script again.

 IMPORTANT NOTE: this script is provided and maintained by Debian and Kali.
 If you find any issue in this script, please report it directly to Debian or Kali

┌──(haye㉿192)-[~]
└─$ sudo greenbone-feed-sync --type scap
Running as root. Switching to user '_gvm' and group '_gvm'.
Trying to acquire lock on /var/lib/gvm/feed-update.lock
Acquired lock on /var/lib/gvm/feed-update.lock
Downloading SCAP data from
rsync://feed.community.greenbone.net/community/vulnerability-feed/24.10/scap-data/ to
/var/lib/gvm/scap-data
Releasing lock on /var/lib/gvm/feed-update.lock
```

```
       Waiting for gvmd service
       OK: gvmd service is active.
       Starting gsad service
       Waiting for gsad service
       OK: gsad service is active.
tep 8: Checking few other requirements...
       OK: nmap is present.
       OK: ssh-keygen found, LSC credential generation for GNU/Linux
targets is likely to work.
       OK: nsis found, LSC credential package generation for Microso
t Windows targets is likely to work.
       OK: xsltproc found.
       WARNING: Your password policy is empty.
       SUGGEST: Edit the /etc/gvm/pwpolicy.conf file to set a passwo
d policy.
tep 9: Checking greenbone-security-assistant...
       OK: greenbone-security-assistant is installed

t seems like your GVM-25.04.0 installation is OK.

┌──(haye㉿192)-[~]
```

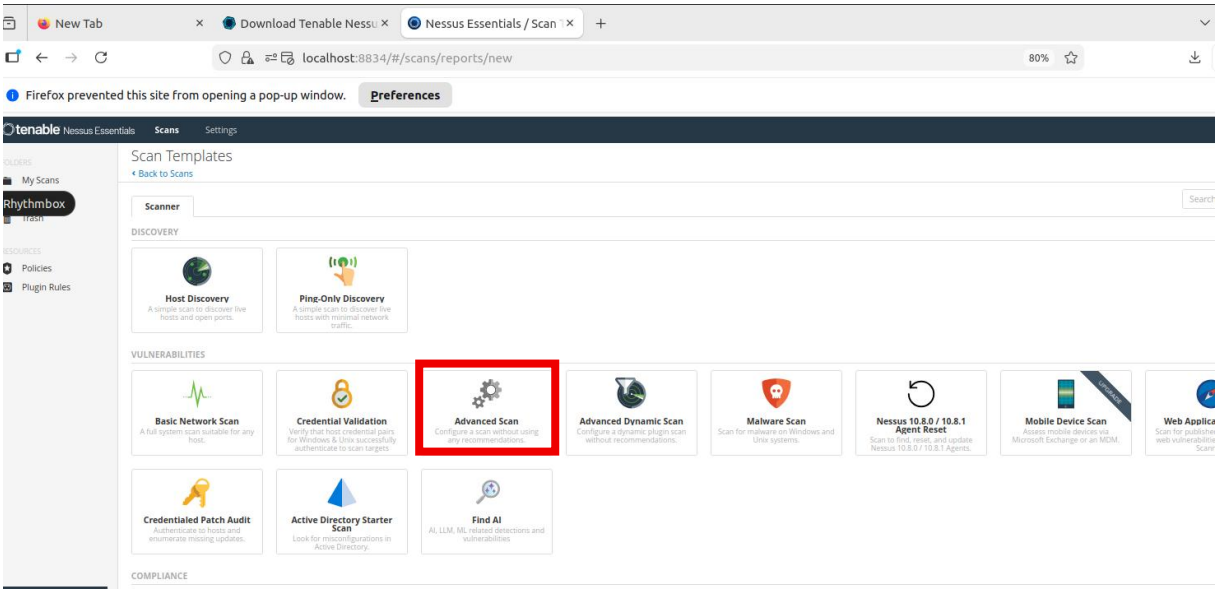
Installation complete

Pour accédé a l’interface de OpenVAS avec http://127.0.0.1:9392





Scan de Nessus



tenable Nessus Essentials | Scans | Settings | nessus

New Scan / Advanced Scan

‹ Back to Scan Templates

FOLDERS
- My Scans
- All Scans
- Trash

RESOURCES
- Policies
- Plugin Rules

Help

Tenable News

Google Cloud Platform (GCP) Google Security Operat...

Settings | **Credentials** | Plugins

CATEGORIES: Host

Filter Credentials

- SNMPv3
- SSH
- Windows

SSH

Authentication method	password
Username	msfadmin
Password (unsafe!)	••••••••
Elevate privileges with	sudo
sudo user	msfadmin
sudo password	••••••••
Location of sudo (directory)	/etc/sudoers
Custom password prompt	password:
Targets to prioritize credentials	

This password could be compromised if Nessus connects to a rogue SSH server. This can be mitigated by providing Nessus with a known_hosts file in the "Global Settings" section below.

Account to escalate to

Some devices are configured to prompt for a password with a non-standard string such as 'secret-passcode: '. This setting allows such prompts to be recognized. Leave this blank for most standard password prompts.

Any hostnames or IPs or CIDR blocks (in a comma or space separated list in this field) that match a scanned system's hostname or IP will attempt to try this credential before other credentials

Upgrade to **Nessus Essentials Plus** for real-time plugin updates, more IPs, and reporting capabilities! UPGRADE NOW

Settings | Credentials | Plugins

BASIC
- General
- Schedule
- Notifications

DISCOVERY

ASSESSMENT

REPORT

ADVANCED

Name	metasploitable2
Description	
Folder	My Scans
Targets	192.168.88.146
Upload Targets	Add File

Save | Cancel

metasploitable2

‹ Back to My Scans

Configure

Hosts 1 | Vulnerabilities 92 | Notes 1 | History 1

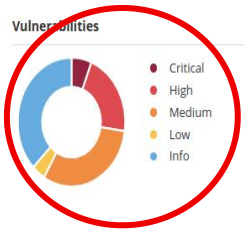
Filter ▾ Search Hosts 1 Host

Host	Auth	Vulnerabilities ▾	%
192.168.88.146	Pass	29 95 141 18 167	100%

Scan Details

Policy:	Advanced Scan
Status:	Processing
Severity Base:	CVSS v3.0
Scanner:	Local Scanner
Start:	Today at 10:36 PM
End:	Today at 10:55 PM

Vulnerabilities



sentials Scans Settings nessu

metasploitable2 / 192.168.88.146

‹ Back to Hosts

Configure Audit Trail

Your license will expire in 20 days, on Jan 22, 2026. Please renew your license for Nessus Essentials by logging into the community portal and requesting a new license.

Vulnerabilities 92

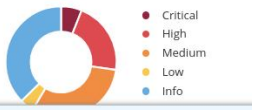
Filter ▾ Search Vulnerabilities 92 Vulnerabilities

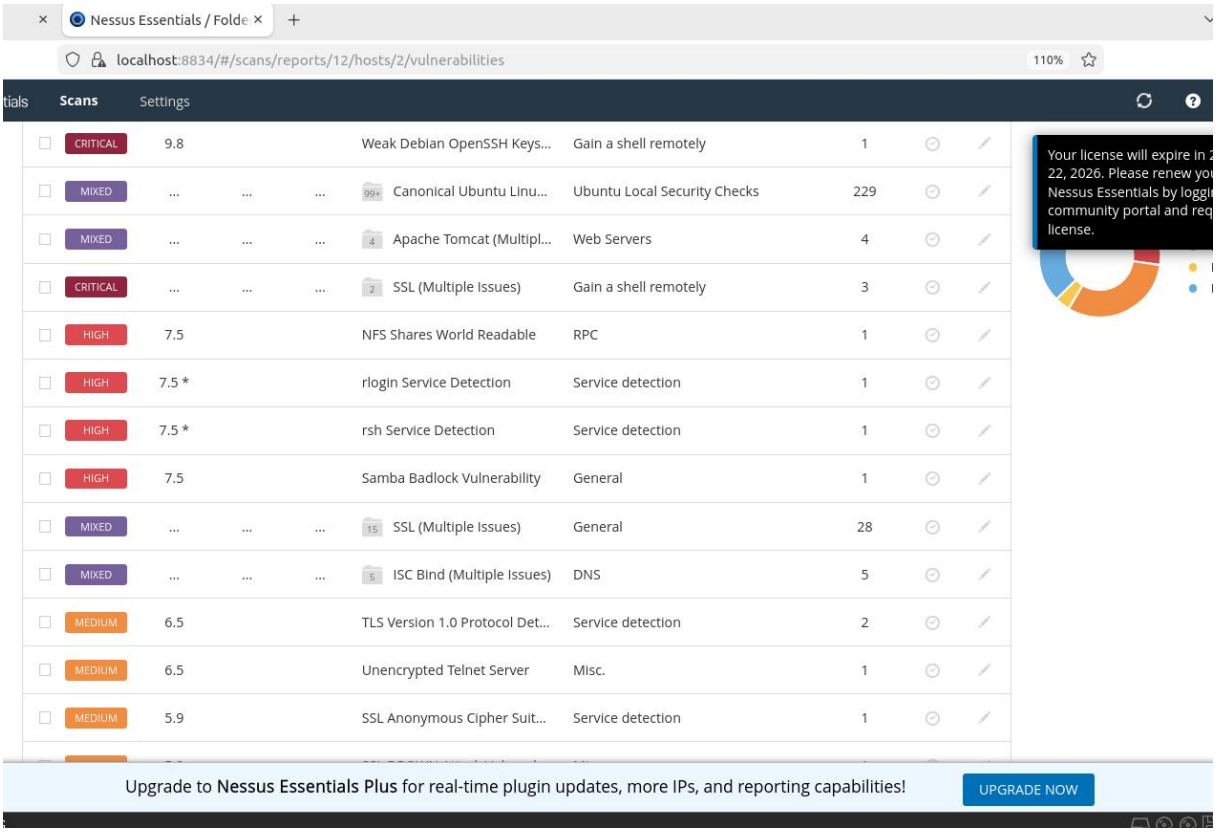
Sev ▾	CVSS ▾	VPR ▾	EPSS ▾	Name ▲	Family ▲	Count ▾
CRITICAL	10.0 *			UnrealIRCd Backdoor Detect...	Backdoors	1
CRITICAL	10.0 *			VNC Server 'password' Pass...	Gain a shell remotely	1
CRITICAL	9.8			SSL Version 2 and 3 Protocol...	Service detection	2
CRITICAL	9.8			Bash Remote Code Executio...	Gain a shell remotely	1
CRITICAL	9.8			Bind Shell Backdoor Detection	Backdoors	1
CRITICAL	9.8			Weak Debian OpenSSH Keys...	Gain a shell remotely	1
MIXED	...	...	...	Canonical Ubuntu Linu...	Ubuntu Local Security Checks	229
MIXED	...	...	...	Apache Tomcat (Multipl...	Web Servers	4
CRITICAL	...	...	...	SSL (Multiple Issues)	Gain a shell remotely	3

Host Details

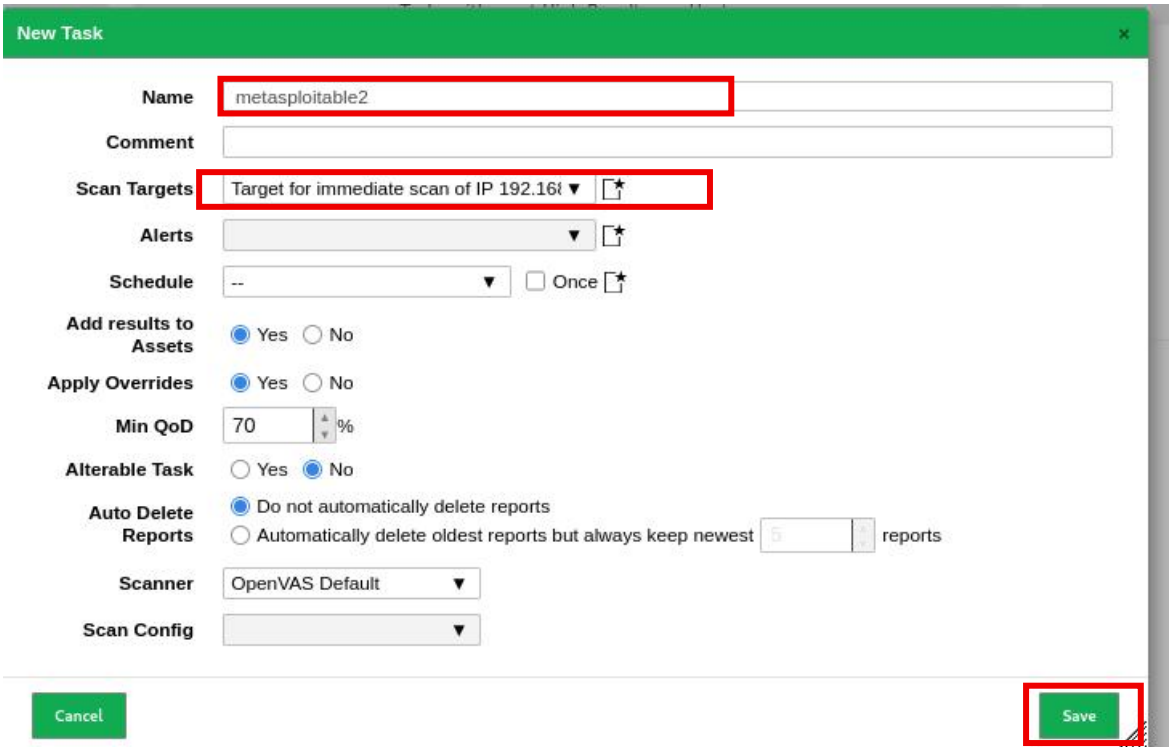
IP:	192.168.88.146
MAC:	00:0C:29:C1:58:F3 00:0C:29:C1:58:FD
OS:	Linux Kernel 2.6.24-16-server or Ubuntu 8.04
Start:	2025-12-29 at 10:36 PM
End:	2025-12-29 at 10:55 PM
Elapsed:	19 minutes
KB:	Download
Auth:	Pass

Vulnerabilities





SCAN DE OPENVAS


New Task
Name
metasploitable2
Comment
Scan Targets
Target for immediate scan of IP 192.168
Alerts
Schedule
--
Once
Add results to Assets
Yes
No
Apply Overrides
Yes
No
Min QoD
70
%
Alterable Task
Yes
No
Auto Delete Reports
Do not automatically delete reports
Automatically delete oldest reports but always keep newest
reports
Scanner
OpenVAS Default
Scan Config
Cancel
Save

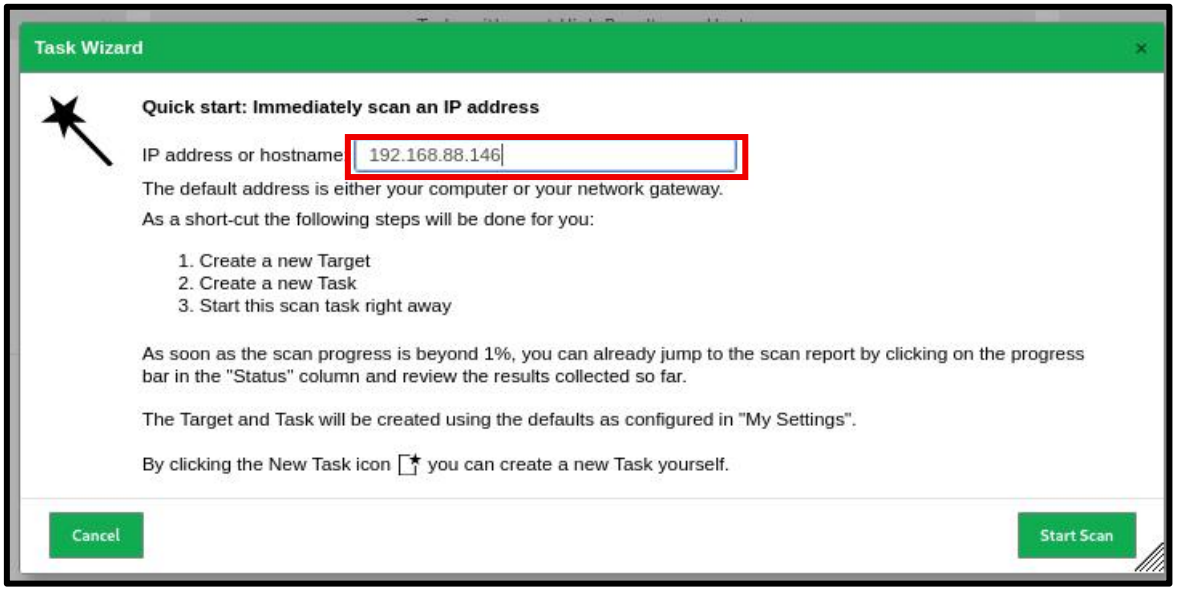

Task Wizard
Quick start: Immediately scan an IP address
IP address or hostname
192.168.88.146
The default address is either your computer or your network gateway.
As a short-cut the following steps will be done for you:
1. Create a new Target
2. Create a new Task
3. Start this scan task right away
As soon as the scan progress is beyond 1%, you can already jump to the scan report by clicking on the progress bar in the "Status" column and review the results collected so far.
The Target and Task will be created using the defaults as configured in "My Settings".
By clicking the New Task icon you can create a new Task yourself.
Cancel
Start Scan

TABLEAU COMPARATIF NESSUS VS OPENVAS

Caractéristique	Nessus	OpenVAS (Greenbone GVM)
Licence / Modèle	Commercial (Tenable), version gratuite (Nessus Essentials) disponible.	Open Source (gratuit).
Facilité d'utilisation	nterface conviviale et intuitive, idéal pour les débutants.	Plus complexe, nécessite une configuration et expertise technique plus poussées
Base de données vulnérabilités	Très vaste, avec plus de 130 000 plugins.	Également riche, surtout avec les flux Enterprise de Greenbone.
Personnalisation	Options de personnalisation avancées pour les scans.	Extrêmement personnalisable (outils open source).
Rapports	HTML, CSV, XML.	HTML, PDF, CSV.
Courbe d'apprentissage	Plus rapide.	Plus abrupte.

COMPARAISON DE VULNÉRABILITÉ DECTER PAR NESSUS VS OPENVAS

Vulnérabilité / CVE	Description	Gravité(CVSS)	Détecté par OpenVAS	Détecté par Nessus
vsftpd 2.3.4 Backdoor (CVE-2011-2523	Service FTP vulnérable avec porte dérobée	Critique (9.3)	oui	oui
Telnet non sécurisé	Connexion en clair,	risque Élevée (7.5)	oui	oui

MySQL sans mot de passe roo	Accès complet à la base de données	Critique (10.0)	oui	oui
Apache Tomcat vulnérable (CVE-2009-3548)	Exécution de code à distance	Élevée (7.0)	oui	non
Services obsolètes (NTP, RPC)	Versions anciennes exposées	Moyenne (5.0	oui	oui

PLAN D'ACTION CORRECTIF

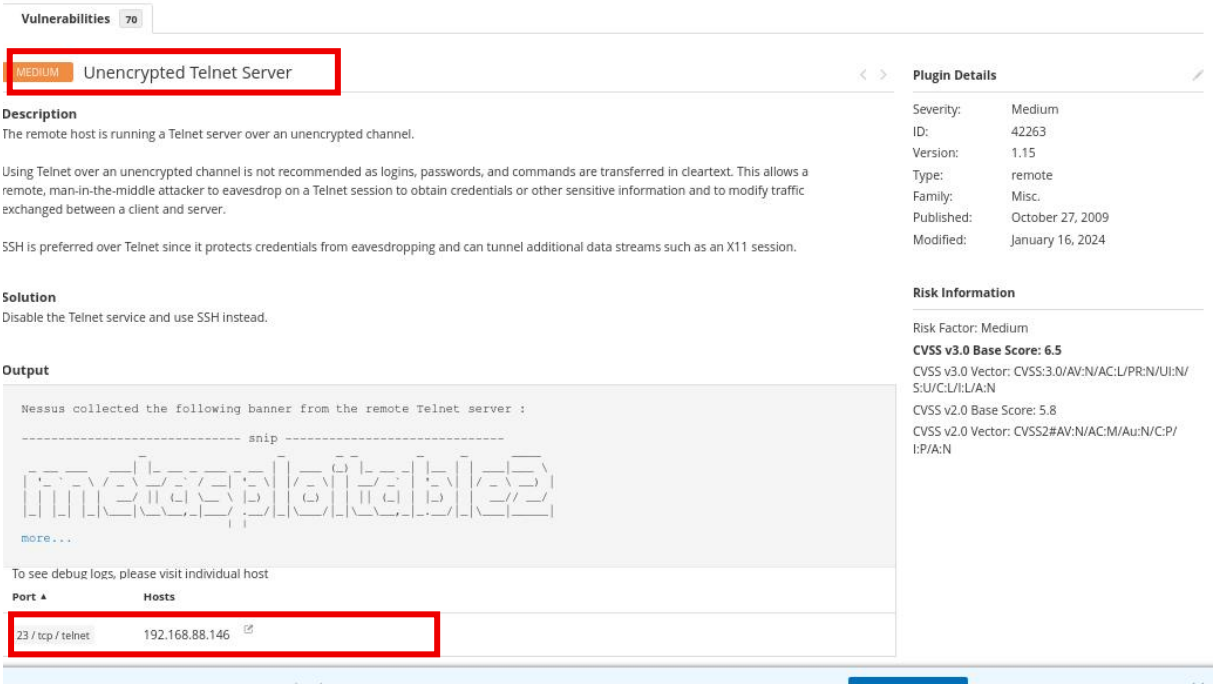
Vulnérabilité Priorité	Risque	Action corrective proposée	Priorité

vsftpd 2.3.4 Backdoor (CVE-2011-2523)	Exécution de code à distance via FTP	Mettre à jour ou désinstaller vsftpd, remplacer par un service FTP sécurisé (SFTP)	Critique
Telnet non sécurisé	Interception des identifiants en clair	Désactiver Telnet, utiliser SSH avec clés et chiffrement	élevé
MySQL sans mot de passe root	Accès complet à la base de données	Définir un mot de passe fort pour root, limiter l'accès	Critique

		réseau	
Apache Tomcat vulnérable	Exécution de code à distance	Mettre à jour Tomcat, appliquer les correctifs de sécurité	Élevée
Samba vulnérable (CVE-2007-2447)	Exécution de commandes via RPC	Mettre à jour Samba, restreindre l'accès aux partages	Critique
Services obsolètes (NTP, RPC, etc.)	Exploitation de failles connues	Désactiver les services inutiles, mettre à jour les	Moyenne

		versions nécessaires	

UN EXEMPLE : CAS DE TELNET



Vulnerabilities 70

MEDIUM Unencrypted Telnet Server

Description

The remote host is running a Telnet server over an unencrypted channel.

Using Telnet over an unencrypted channel is not recommended as logins, passwords, and commands are transferred in cleartext. This allows a remote, man-in-the-middle attacker to eavesdrop on a Telnet session to obtain credentials or other sensitive information and to modify traffic exchanged between a client and server.

SSH is preferred over Telnet since it protects credentials from eavesdropping and can tunnel additional data streams such as an X11 session.

Solution

Disable the Telnet service and use SSH instead.

Output

```
Nessus collected the following banner from the remote Telnet server :

------------------------------ snip ------------------------------
more...
```

To see debug logs, please visit individual host

Port ▲	Hosts
23 / tcp / telnet	192.168.88.146

Plugin Details

Severity:	Medium
ID:	42263
Version:	1.15
Type:	remote
Family:	Misc.
Published:	October 27, 2009
Modified:	January 16, 2024

Risk Information

Risk Factor: Medium

CVSS v3.0 Base Score: 6.5

CVSS v3.0 Vector: CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N

CVSS v2.0 Base Score: 5.8

CVSS v2.0 Vector: CVSS2#AV:N/AC:M/Au:N/C:P/I:P/A:N

Je voulais m'assurer de l'existence ou non de cette vulnérabilité sous Linux. Pour cela, Nmap me sera utile pour analyser les ports

nmap -sV (Adresse_IP_cible)

```
mariem@mariem-virtual-machine:~$ nmap -sV 192.168.88.146
Starting Nmap 7.80 ( https://nmap.org ) at 2025-12-28 16:05 GMT
Nmap scan report for 192.168.88.146 (192.168.88.146)
Host is up (0.0021s latency).
Not shown: 977 closed ports
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec?
513/tcp  open  login       OpenBSD or Solaris rlogind
514/tcp  open  tcpwrapped
```

Oui, j'ai vu que le service telnet est ouvert sur le port 23. Je peux accéder à la machine vulnérable à Metasploit avec cette commande.

telnet 192.168.88.146

```
ariem@mariem-virtual-machine:~$ telnet 192.168.88.146
rying 192.168.88.146...
onnected to 192.168.88.146.
scape character is '^]'.

arning: Never expose this VM to an untrusted network!

ontact: msfdev[at]metasploit.com

ogin with msfadmin/msfadmin to get started
Welcome to Ubuntu
etasploitable login: msfadmin
assword:
ast login: Sun Dec 28 10:15:35 EST 2025 on tty1
inux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

he programs included with the Ubuntu system are free software;
he exact distribution terms for each program are described in the
ndividual files in /usr/share/doc/*/copyright.

buntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
pplicable law.

o access official Ubuntu documentation, please visit:
```

```
msfadmin@metasploitable:~$ sudo -l
[sudo] password for msfadmin:
User msfadmin may run the following commands on this host:
    (ALL) ALL
msfadmin@metasploitable:~$
```

Il existe de nombreuses techniques et méthodes pour obtenir ces privilèges. Je pense que voici la meilleure façon de procéder :

sudo -l

Je peux tout voir. Cela signifie que je peux exécuter toutes les commandes. Essayons donc de discuter. Je souhaite consulter le répertoire /etc/passwd. Ci-dessous, nous sommes connectés en tant qu'utilisateur root et nous avons vu les résultats.

```
msfadmin@metasploitable:~$ sudo su
root@metasploitable:/home/msfadmin# cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534::/:/bin/false
user:x:1001:1001:just a user,111,,:/home/user:/bin/bash
service:x:1002:1002:,,,:/home/service:/bin/bash
telnetd:x:112:120::/nonexistent:/bin/false
proftpd:x:113:65534::/var/run/proftpd:/bin/false
statd:x:114:65534::/var/lib/nfs:/bin/false
Show Applications
root@metasploitable:/home/msfadmin#
```

Nous pouvons consulter la liste complète. Cette ls -la commande est utilisée sous Linux et les systèmes d'exploitation de type Unix. Elle liste les fichiers et répertoires du répertoire courant. Voici son utilisation de base ls -la

Cette commande permet de lister tous les fichiers et répertoires de manière détaillée, en fournissant des informations telles que les permissions, le propriétaire, le groupe, la taille, la date de modification et le nom du fichier ou du répertoire

Je souhaite modifier les permissions du fichier .profile.

chmod +x .profile

```
root@metasploitable:/home/msfadmin# ls -la
total 36
drwxr-xr-x 5 msfadmin msfadmin 4096 2012-05-20 14:22 .
drwxr-xr-x 6 root     root     4096 2010-04-16 02:16 ..
lrwxrwxrwx 1 root     root        9 2012-05-14 00:26 .bash_history -> /dev/null
drwxr-xr-x 4 msfadmin msfadmin 4096 2010-04-17 14:11 .distcc
-rw------- 1 root     root     4174 2012-05-14 02:01 .mysql_history
-rw-r--r-- 1 msfadmin msfadmin  586 2010-03-16 19:12 .profile
-rwx------ 1 msfadmin msfadmin    4 2012-05-20 14:22 .rhosts
drwx------ 2 msfadmin msfadmin 4096 2010-05-17 21:43 .ssh
-rw-r--r-- 1 msfadmin msfadmin    0 2010-05-07 14:38 .sudo_as_admin_successful
drwxr-xr-x 6 msfadmin msfadmin 4096 2010-04-27 23:44 vulnerable
root@metasploitable:/home/msfadmin# chmod +x .profile
root@metasploitable:/home/msfadmin# ls -la
total 36
drwxr-xr-x 5 msfadmin msfadmin 4096 2012-05-20 14:22 .
drwxr-xr-x 6 root     root     4096 2010-04-16 02:16 ..
lrwxrwxrwx 1 root     root        9 2012-05-14 00:26 .bash_history -> /dev/null
drwxr-xr-x 4 msfadmin msfadmin 4096 2010-04-17 14:11 .distcc
-rw------- 1 root     root     4174 2012-05-14 02:01 .mysql_history
-rwxr-xr-x 1 msfadmin msfadmin  586 2010-03-16 19:12 .profile
-rwx------ 1 msfadmin msfadmin    4 2012-05-20 14:22 .rhosts
drwx------ 2 msfadmin msfadmin 4096 2010-05-17 21:43 .ssh
-rw-r--r-- 1 msfadmin msfadmin    0 2010-05-07 14:38 .sudo_as_admin_successful
drwxr-xr-x 6 msfadmin msfadmin 4096 2010-04-27 23:44 vulnerable
root@metasploitable:/home/msfadmin#
```

Oui, j'ai vu que les autorisations ont été modifiées en bas de la page.

Cette sudo iptables -L commande permet d'afficher les règles du pare-feu iptables sur un système Linux. Iptables C'est un outil puissant pour configurer le pare-feu du noyau Linux, qui contrôle le trafic réseau du système.

sudo iptables -L

- Sudo Exécute la commande suivante avec des privilèges élevés. Vous aurez peut-être besoin des droits de superutilisateur (root) pour consulter ou modifier les règles du pare-feu.
- iptables: La commande permettant de gérer les règles de filtrage des paquets du noyau Linux.

- -L: Affiche la liste des règles. Sans options supplémentaires, elle présente l'ensemble de règles actuel pour la table spécifiée (généralement la table de filtre, qui est la valeur par défaut).

```
root@metasploitable:/home/msfadmin# sudo iptables -L
Chain INPUT (policy ACCEPT)
target     prot opt source               destination

Chain FORWARD (policy ACCEPT)
target     prot opt source               destination

Chain OUTPUT (policy ACCEPT)
target     prot opt source               destination
root@metasploitable:/home/msfadmin#
```

Je souhaite maintenant désactiver l'utilisation de ce port. Si je le désactive, je ne pourrai plus effectuer d'intrusion.

sudo iptables -A INPUT -p tcp --dport 23 -j DROP

Cette règle bloque efficacement les connexions entrantes sur le port 23, port par défaut du service Telnet. Telnet étant un protocole non sécurisé, bloquer l'accès à ce port renforce la sécurité. Si vous avez un besoin spécifique de bloquer Telnet, cette règle répondra à ce besoin.

Après avoir fermé le port 23, n'oubliez pas d'enregistrer l'état d'iptables.

sudo iptables-save

Appuyez sur Entrée ou cliquez pour afficher l'image en taille réelle

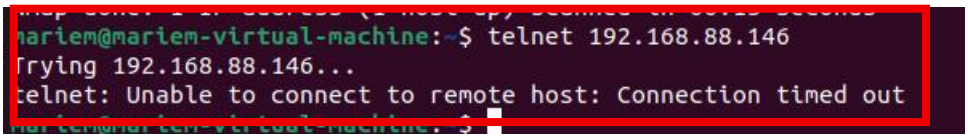
```
mariem@mariem-virtual-machine:~$ sudo iptables -A INPUT -p tcp --dp
LibreOffice Writer
mariem@mariem-virtual-machine:~$ sudo iptables-save
# Generated by iptables-save v1.8.7 on Mon Dec 29 21:33:22 2025
*filter
:INPUT ACCEPT [0:0]
:FORWARD ACCEPT [0:0]
:OUTPUT ACCEPT [0:0]
-A INPUT -p tcp -m tcp --dport 23 -j DROP
-A INPUT -p tcp -m tcp --dport 23 -j DROP
COMMIT
# Completed on Mon Dec 29 21:33:22 2025
```

Une double vérification serait préférable. Comme vous pouvez le constater ci-dessous, le service telnet, qui utilise le port 23, a été filtré.

```
mariem@mariem-virtual-machine:~$ nmap -sV 192.168.88.146
Starting Nmap 7.80 ( https://nmap.org ) at 2025-12-30 23:27 GMT
Nmap scan report for 192.168.88.146 (192.168.88.146)
Host is up (0.0033s latency).
Not shown: 977 closed ports
PORT     STATE    SERVICE     VERSION
21/tcp   open     ftp         vsftpd 2.3.4
22/tcp   open     ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   filtered telnet
25/tcp   open     smtp        Postfix smtpd
53/tcp   open     domain      ISC BIND 9.4.2
80/tcp   open     http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open     rpcbind     2 (RPC #100000)
139/tcp  open     netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open     netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open     exec?
513/tcp  open     login       OpenBSD or Solaris rlogind
514/tcp  open     tcpwrapped
1099/tcp open     java-rmi    GNU Classpath grmiregistry
1524/tcp open     bindshell   Metasploitable root shell
2049/tcp open     nfs         2-4 (RPC #100003)
2121/tcp open     ftp         ProFTPD 1.3.1
3306/tcp open     mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open     postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open     vnc         VNC (protocol 3.3)
6000/tcp open     X11         (access denied)
6667/tcp open     irc         UnrealIRCd
8009/tcp open     ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open     http        Apache Tomcat/Coyote JSP engine 1.1
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 66.13 seconds
mariem@mariem-virtual-machine:~$
```

Dernière vérification avec la commande telnet. J'ai confirmé que l'accès à MS2 depuis ubuntu est impossible, car j'ai désactivé le port.

Il s'agit donc d'une simple précaution.



Par conséquent, nous avons installé Nessus, effectué une analyse avancée avec les identifiants MS2, puis accédé au système via telnet et renforcé les autorisations. Par précaution, nous avons récemment désactivé le port telnet 23.